

NOVACRED AI GOVERNANCE PROGRAM

An End-to-End AI Risk Assessment Framework for a Regulated Fintech

*Applying NIST AI RMF, EU AI Act, GDPR and ISO/IEC 42001 to a Simulated Credit Fintech:
Risk classification, applied case analysis, and executive reporting.*

Rebecca Froes

September 2026

Aligned to: NIST AI RMF 1.0 · EU AI Act · GDPR · ISO/IEC 42001

Table of Contents

Company Context	1
1. Framework Methodology	2
1.1 Scope & Applicability	2
1.2 Scoring Dimensions	2
1.3 Design Rationale	3
2. Risk Classification Matrix	4
3. Applied Case Assessments	5
3.1 Case A: Credit Scoring Engine	5
3.2 Case B: NovaAssist Chatbot	6
3.3 Case C: Fraud & AML Detection	7
4. Executive Memo	8
5. Design Decision Log	9

Company Context

NovaCred is a simulated mid-size digital lending fintech (200 employees) operating in the EU, with an expansion track into the US market. It offers fully digital personal and small-business credit, with no physical branch network. Having scaled quickly, its AI governance maturity has not kept pace with its product surface, the premise for this program.

AI Systems in Scope

- Credit Scoring Engine: An AI system used to assess applicants' creditworthiness and support loan approval and interest-rate decisions.
- NovaAssist: an LLM-based customer-service assistant that answers questions about accounts and loans and may provide financial guidance.
- Fraud & AML Detection System: An AI-based system that identifies potentially suspicious transactions and generates alerts for human review.

1. Framework Methodology

1.1 Scope & Applicability

For the purposes of this assessment, an AI system is defined using ISO/IEC 22989:2022 as the baseline terminology. The standard defines an AI system as an engineered system that generates outputs such as content, forecasts, recommendations or decisions for a given set of human-defined objectives. This definition is applied to systems that use AI techniques to generate outputs that support, influence or make decisions within NovaCred's business processes. Based on this definition, three AI-enabled systems are included in the assessment:

- Credit Scoring Engine
- NovaAssist
- Fraud & AML Detection System

Systems Out of Scope: Non-AI software, conventional business applications and IT infrastructure that do not generate AI-based outputs are outside the scope of this assessment. The assessment also does not evaluate broader enterprise risks unrelated to the use or governance of AI.

1.2 Scoring Dimensions

Each system is scored across four independent dimensions rather than a single impact x probability score, to avoid collapsing distinct risk types into one misleading number:

- Legal & regulatory exposure: Assesses the extent to which the AI system may trigger or be subject to legal and regulatory obligations, e.g. EU AI Act obligations, GDPR requirements, sector-specific financial regulation and other applicable legal requirements.
- Impact to individuals: Assesses the potential consequences of the AI system for individuals or groups affected by its outputs, e.g. fundamental rights, safety, economic opportunity, discrimination and other potential harms.

- **Operational / business impact:** Assesses the potential consequences of AI-related failures or risks for NovaCred's operations and business, e.g. financial impact, reputational damage, operational continuity and customer/business disruption.
- **Technical uncertainty:** Assesses the degree of uncertainty associated with the system's behavior, performance and ability to be effectively controlled, e.g. explainability, data quality, model drift, performance limitations and human oversight gaps.

Scoring Scale

Score	Level	General interpretation
1	Low	Limited exposure or potential impact
2	Moderate	Relevant exposure requiring standard controls
3	High	Significant exposure requiring enhanced controls and monitoring
4	Critical	Severe exposure requiring the highest level of governance attention

1.2.1 Tier Aggregation Rule

The assessment uses an internal NovaCred AI Risk Tier as a governance classification. This internal taxonomy is distinct from, and does not replace, the legal risk classifications established by applicable regulation. The original draft scored each system across four dimensions but did not state how those scores combine into a single Risk Tier. This produced an inconsistency: NovaAssist scored High (3) on both Impact to Individuals and Technical Uncertainty, yet was classified as Limited without an explanation of why two High scores did not raise the tier. This revision makes the aggregation logic explicit:

- **Primary anchor: regulatory classification:** The internal Risk Tier is anchored first to whether the system falls within a legally defined high-risk or prohibited use case. Under the EU AI Act, AI systems intended to evaluate the creditworthiness or credit score of natural persons are listed as high-risk under Annex III, point 5(b). The internal tier therefore reflects the applicable regulatory classification where one exists.
- **Secondary modulation: dimension scores:** For systems that do not fall within a legally defined prohibited or high-risk category, the highest individual dimension score informs the internal tier and determines whether enhanced monitoring is required. A system with one or more High (3) dimension scores that remains outside the relevant regulatory high-risk classification may be classified as Limited with an Enhanced Monitoring Flag rather than having the elevated dimension score silently absorbed into a lower classification.
- **Escalation trigger:** Any Critical (4) score on Legal & Regulatory Exposure or Impact to Individuals automatically elevates the system to at least the internal High tier, irrespective of the other three scores. This is an internal governance escalation rule

and does not by itself establish that the system is legally classified as high-risk under the EU AI Act.

Applying this rule:

- The Credit Scoring Engine is internally classified as High and independently falls within EU AI Act Annex III, point 5(b), based on its use to evaluate the creditworthiness of natural persons.
- NovaAssist does not make or materially influence a credit, eligibility, or comparable consequential decision and therefore does not meet the regulatory high-risk use case considered in this assessment. It remains Limited under NovaCred's internal taxonomy but carries an Enhanced Monitoring Flag because of its two High dimension scores.
- The Fraud & AML Detection System is internally classified as High because of its Critical Impact to Individuals score. However, this internal classification should not be interpreted as an EU AI Act high-risk classification. The EU AI Act specifically provides that certain AI systems intended for detecting fraud in the offering of financial services are not considered high-risk under the Act. The applicable regulatory classification therefore requires separate legal assessment of the system's exact purpose and legal context.

1.3 Design Rationale

The four-dimensional scoring structure was selected to preserve the distinct nature of AI-related risks. Rather than combining impact and probability into a single score, the methodology assesses Legal & Regulatory Exposure, Impact to Individuals, Operational / Business Impact, and Technical Uncertainty independently. This approach allows the assessment to distinguish between different sources and consequences of risk, while avoiding the loss of relevant information that can occur when different risk types are reduced to a single numerical value. The tier aggregation rule in Section 1.2.1 preserves this same principle one level up: it prevents a single high dimension score from being silently smoothed into an average, while also preventing a system from inheriting a high tier purely because one dimension spiked, absent an actual Annex III-level use case.

Dimension-Specific Criteria

Dimension	Low	Moderate	High	Critical
Legal & Regulatory Exposure	Limited or no specific AI-related regulatory obligations identified	Some applicable AI/data/sectoral requirements	Multiple significant regulatory requirements or heightened compliance obligations	Extensive or particularly consequential regulatory obligations; significant legal exposure if controls fail
Impact to Individuals	Limited, reversible consequences for individuals	Meaningful but generally manageable consequences	Significant effects on rights, safety, economic opportunities or equal treatment	Potential for severe or widespread harm to fundamental rights, safety or economic opportunities
Operational / Business Impact	Limited disruption or financial/reputational consequences	Manageable operational, financial or reputational impact	Significant financial, operational, customer or reputational	Severe financial/reputational impact or major

			consequences	disruption to critical business operations
Technical Uncertainty	Well-understood system with strong explainability, reliable data and effective oversight	Some limitations or uncertainties requiring monitoring	Significant uncertainty involving explainability, data quality, drift or oversight	Material uncertainty or lack of effective control over system behavior, performance or human oversight

2. Risk Classification Matrix

Internal Risk Tier	Criteria	Example Obligation / Governance Response	Escalation Path
Unacceptable / Prohibited Use	AI systems involving prohibited practices or uses that create unacceptable risks to individuals or society under applicable law.	Prohibition or immediate discontinuation of the use case.	Immediate halt — Legal + Executive Management
High	AI systems that materially influence consequential decisions affecting individuals, particularly where access to credit, financial services, employment, essential services, or fundamental rights may be affected. Regulatory high-risk classifications should be separately documented where applicable.	Enhanced risk controls, human oversight, documentation, monitoring and applicable regulatory requirements.	AI Governance / Risk Committee
Limited	AI systems with limited direct impact on individuals but where transparency, disclosure, user-awareness or other controls may apply. May carry an Enhanced Monitoring Flag where one or more individual dimension scores are High.	Transparency, disclosure, user notification or other applicable controls.	Product + Compliance
Minimal	AI systems with limited impact on individuals, limited regulatory exposure, and no significant consequential decision-making function.	Basic governance controls or voluntary codes of conduct.	Business Owner / Self-Assessment

3. Applied Case Assessments

Framework applied to three fictional AI systems, each selected to assess a different AI governance scenario.

3.1 Case A: Credit Scoring Engine

Baseline: The Credit Scoring Engine assesses applicants' creditworthiness using financial and behavioral data and supports loan approval and interest-rate decisions. The system may directly affect individuals' access to credit and financial opportunities.

Regulatory Classification

This system falls within EU AI Act Annex III, point 5(b), which designates AI systems intended to be used to evaluate the creditworthiness of natural persons or establish their credit score as high-risk AI systems. The system should therefore be assessed against the applicable high-risk AI requirements under the EU AI Act, including requirements relating to risk management, data governance, technical documentation, human oversight and applicable conformity requirements. The exact obligations depend on NovaCred's role and the system's deployment context. (EU AI Act, Annex III, point 5(b), and applicable high-risk provisions.) Because the system also uses applicant data to produce an automated output that materially affects loan approval and pricing, NovaCred should separately assess whether the decision qualifies as a decision based solely on automated processing under GDPR Article 22(1).NovaCred should therefore determine:

- 1. whether the decision is solely automated;
- 2. whether the decision produces legal effects or similarly significantly affects the individual;
- 3. whether an Article 22(2) exception applies if Article 22(1) is engaged; and
- 4. what safeguards are required, including applicable rights to human intervention, to express the individual's point of view and to contest the decision.

A human reviewer should not be treated as automatically removing Article 22 considerations; the assessment should determine whether the human involvement is substantive enough to change the nature of the decision-making process. (GDPR, Article 22.)

Risk Analysis

Dimension	Score	Rationale
Legal & Regulatory Exposure	4 = Critical	The system supports consequential credit decisions and falls within EU AI Act Annex III, point 5(b); GDPR Article 22 also requires a separate assessment where decisions are based solely on automated processing.
Impact to Individuals	4 = Critical	Decisions may affect access to credit and financial opportunities.
Operational / Business Impact	3 = High	Errors or inappropriate decisions could result in financial, regulatory and reputational consequences.

Technical **3 =** Model explainability, data quality, bias and
Uncertainty **High** performance require continuous monitoring.

Internal NovaCred Risk Tier: HIGH

Regulatory Classification: EU AI Act High-Risk

The Critical scores trigger NovaCred's internal High tier, while the Annex III classification independently establishes the applicable regulatory high-risk category.

Recommended Controls

Control	Owner	Frequency	Priority	Evidence / KPI
Bias and fairness assessment	AI Governance / Risk	Quarterly	Immediate	Fairness assessment report and documented metrics
Model performance and drift monitoring	Model Risk / Data Science	Monthly	Immediate	Performance and drift monitoring report
Human review of adverse decisions	Credit Risk	Continuous	Immediate	Human-review logs and override records
Article 22 conformity assessment	Legal / DPO	Annually or on material model change	Immediate	Documented Article 22 assessment and safeguards

The Article 22 assessment should determine whether the decision falls within Article 22(1), whether an applicable exception under Article 22(2) exists, and whether the required safeguards are documented and operating.

Residual Risk Accepted

Residual risk remains due to potential model error, data limitations, bias and uncertainty in automated credit assessment. NovaCred accepts this residual risk subject to continuous monitoring, documented human oversight, periodic reassessment and documented accountability for unresolved risks.

3.2 Case B: NovaAssist Chatbot

Baseline

NovaAssist is an LLM-based customer-service chatbot that answers questions about accounts, loans and financial products. The system interacts directly with customers and may provide information that could be interpreted as individualized financial guidance.

Risk Analysis

Dimension	Score	Rationale
Legal & Regulatory Exposure	2 = Moderate	Transparency and disclosure requirements may apply depending on the system's functionality and use.
Impact to Individuals	3 = High	Incorrect or misleading information could influence customers' financial decisions.
Operational / Business Impact	2 = Moderate	Incorrect responses may generate complaints, reputational damage and customer-service costs.
Technical Uncertainty	3 = High	LLM outputs may be inaccurate, inconsistent or difficult to predict.

Risk Tier: LIMITED, with Enhanced Monitoring Flag

NovaAssist does not make or materially influence a credit, eligibility, or comparable consequential decision, and does not fall within an EU AI Act Annex III category, so it does not meet the primary anchor for High tier under Section 1.2.1. However, it carries two High (3) dimension scores — Impact to Individuals and Technical Uncertainty — which the aggregation rule requires to be surfaced rather than absorbed into a plain Limited rating. The system is therefore classified as Limited tier with an Enhanced Monitoring Flag: appropriate provided it remains scoped to customer support, does not begin approving or pricing credit, and the controls below are in place. If NovaAssist's role expands to producing outputs that materially influence a credit or eligibility decision, it should be rescored against Section 3.1's logic and would likely move to High tier.

Recommended Controls

Control	Owner	Frequency	Priority
AI disclosure to users	Product / Compliance	Continuous	Immediate
Response accuracy testing	AI Governance / Product	Monthly	Near-term
Escalation to human agents	Customer Operations	Continuous	Near-term
Scope boundary review (new)	AI Governance / Product	Quarterly	Near-term

The fourth control row is new: it confirms NovaAssist has not drifted into producing outputs that function as individualized financial advice or that materially influence a credit decision — the condition on which its Limited tier depends.

Residual Risk Accepted

Residual risk remains due to the possibility of inaccurate or inappropriate generated responses. NovaCred accepts this risk subject to monitoring, user disclosure and human escalation mechanisms.

3.3 Case C: Fraud & AML Detection

Baseline: The Fraud & AML Detection System analyzes transaction and account activity to identify potentially suspicious behavior and generates alerts for human review. The system supports fraud prevention and financial crime compliance activities.

Risk Analysis

Dimension	Score	Rationale
Legal & Regulatory Exposure	3 = High	The system supports financial crime compliance and may affect regulatory processes. Its exact regulatory classification requires assessment of its specific purpose and applicable financial-sector requirements.
Impact to Individuals	4 = Critical	False positives may result in investigations, transaction restrictions or delays affecting customers.
Operational / Business Impact	4 = Critical	Detection failures may create financial, regulatory and reputational consequences.
Technical Uncertainty	3 = High	Detection accuracy, false positives, data quality and model drift require continuous monitoring.

Internal NovaCred Risk Tier: HIGH

The Critical score on Impact to Individuals independently triggers NovaCred's internal High tier. However, this internal High classification should not be interpreted as an EU AI Act High-Risk classification. The EU AI Act specifically provides that certain AI systems intended for detecting fraud in the offering of financial services are not considered high-risk under the Act. NovaCred should therefore conduct a separate legal assessment of the system's exact purpose and regulatory context rather than deriving its EU AI Act status from the internal risk score alone.

Recommended Controls

Control	Owner	Frequency	Priority	Evidence / KPI
False-positive	AML /	Weekly	Immedi	False-positive rate and

monitoring	Compliance		ate	investigation outcomes
Threshold and model performance review	Model Risk / AML	Monthly	Immediate	Performance, threshold and drift reports
Human investigation of alerts	AML Operations	Continuous	Immediate	Investigation logs and disposition records

Residual Risk Accepted

Residual risk remains because automated detection cannot completely eliminate false positives or false negatives. NovaCred accepts this residual risk subject to human investigation, continuous monitoring, periodic threshold reassessment and documented accountability for unresolved risks.

4. Executive Memo

Executive Summary

NovaCred's AI governance assessment identified different levels of risk across the three in-scope AI systems. The assessment considered Legal & Regulatory Exposure, Impact to Individuals, Operational / Business Impact, and Technical Uncertainty, aggregated into an internal NovaCred Risk Tier using the explicit rule set out in Section 1.2.1.

Regulatory classifications were assessed separately from the internal risk taxonomy to avoid treating NovaCred's internal governance categories as direct substitutes for legal classifications.

Key Findings

AI System	Internal Risk Tier	Regulatory Consideration	Key Risk
Credit Scoring Engine	HIGH	EU AI Act Annex III, point 5(b): High-Risk	Consequential credit decisions, fairness, regulatory exposure and potential GDPR Article 22 implications
NovaAssist Chatbot	LIMITED — Enhanced Monitoring	No high-risk classification identified within the defined use case	Transparency, inaccurate outputs and potential financial guidance
Fraud &	HIGH	Internal High	Customer impact, false

AML Detection	classification; EU AI Act status requires separate assessment of the specific fraud-detection use case	positives and compliance consequences
--------------------------	--	---------------------------------------

Priority Actions

- Strengthen governance and human oversight for the Credit Scoring Engine, including completion and documentation of the GDPR Article 22 assessment.
- Implement transparency, monitoring and scope-boundary controls for NovaAssist, and reassess its regulatory classification if its role expands toward credit or eligibility decisions.
- Establish continuous false-positive and model-performance monitoring for Fraud & AML Detection.
- Maintain documented ownership and accountability for AI-related risks.
- Maintain separate records of internal risk classification and applicable regulatory classification.
- Conduct periodic reassessment as systems, models, data, use cases and regulatory requirements change, using the tier aggregation rule in Section 1.2.1 as the standing internal methodology.

Management Considerations

The assessment indicates that AI governance should be proportionate to the potential impact and regulatory context of each system. High internal-risk systems require stronger oversight, monitoring and documentation. Limited-risk systems require controls appropriate to their specific use and potential impact. Systems that carry an Enhanced Monitoring Flag, such as NovaAssist, should not be treated as equivalent to a plain Limited-risk system for monitoring purposes, even though their governance requirements may remain lighter than those applicable to a High-risk system. Management should also distinguish between:

- Internal governance risk: NovaCred's assessment of the level of governance attention required; and
- Regulatory classification: the legal classification established under the applicable regulatory framework.

Overall Recommendation

NovaCred should maintain a risk-based AI governance program in which controls, oversight and monitoring are aligned with the risk profile and regulatory context of each system.

5. Design Decision Log

Decision	Rationale	Alternative Considered	Final Choice
Use four independent scoring dimensions	Separates regulatory, individual, business and technical risks.	Single overall risk score	Four-dimensional assessment
Use a 1–4 scoring scale	Provides sufficient differentiation without excessive complexity.	1–5 or 1–10 scale	1–4 scale
Use four internal Risk Tiers	Creates a consistent governance classification across NovaCred's AI systems without presenting the taxonomy as a reproduction of the EU AI Act.	Directly copy EU AI Act categories	Internal taxonomy mapped to relevant regulatory concepts
Keep risk dimensions separate from the final Risk Tier	Prevents different types of risk from being hidden within a single numerical score.	Add all dimension scores together	Qualitative classification based on the defined criteria
Include human oversight as a key control	AI systems can produce errors or uncertain outputs, particularly in consequential use cases.	Fully automated decision-making	Human oversight for consequential decisions
Treat residual	Controls reduce risk but do	Assume controls	Document and assign

risk separately	not necessarily eliminate it.	eliminate identified risks	remaining residual risk
------------------------	-------------------------------	----------------------------	-------------------------

Apply proportional governance	Different AI systems create different levels and types of risk.	Apply identical controls to every system	Controls proportional to the system's risk profile
--------------------------------------	---	--	--

Reassess systems periodically	AI models, data, use cases and regulatory requirements can change over time.	One-time assessment	Continuous monitoring and periodic reassessment
--------------------------------------	--	---------------------	---

Define an explicit tier-aggregation rule	Dimension scores alone did not determine the internal tier in the original draft, which allowed a system with two High scores to be classified as Limited without a stated reason. An explicit rule makes the classification defensible and repeatable.	Leave tier assignment as a qualitative judgment call per system	Internal tier anchored to regulatory/use-case classification, with an escalation trigger for Critical scores and an Enhanced Monitoring Flag for High scores that do not independently establish a higher regulatory classification
---	---	---	---

Distinguish internal risk tier from regulatory classification	An internal governance score should not be presented as a legal determination under the EU AI Act.	Treat internal tiers as equivalent to EU AI Act categories	Maintain separate internal and regulatory classifications
--	--	--	---

Cite the specific EU AI Act provision for high-risk credit systems	An unreferenced "high-risk" label is difficult to trace. Annex III, point 5(b), provides the relevant regulatory basis for creditworthiness assessment of	State the Annex III classification generically without pinpointing the provision	Cite EU AI Act Annex III, point 5(b) directly in Sections 2 and 3.1
---	---	--	---

natural persons.

Apply GDPR Article 22 carefully to the Credit Scoring Engine	GDPR Article 22 concerns decisions based solely on automated processing that produce legal or similarly significant effects. The assessment should determine whether the decision meets those conditions and, if so, which exception and safeguards apply.	Treat human review as automatically excluding Article 22	Conduct a documented Article 22 conformity assessment
Treat Fraud & AML classification separately	An internal High risk score does not by itself establish EU AI Act High-Risk status. The AI Act provides specific treatment for certain fraud-detection systems in financial services.	Automatically classify the system as EU AI Act High-Risk because of its internal score	Maintain an internal High tier while separately assessing the applicable regulatory classification
Add evidence / KPI to controls	Governance controls need observable evidence to demonstrate that they are operating effectively.	Define controls without evidence requirements	Assign an evidence source or KPI to each major control
Document management actions	AI governance findings should support accountable decision-making, not only risk identification.	Present findings without decision ownership	Define priority actions and management considerations